

Known Issues & Limitations — Project Pegasus

Date: 2026-04-09 | **Version:** 1.0 **Classification:** Internal — Not for external distribution

1. Critical Limitations

1.1 Dev Environment Partially Down

Impact: CRITICAL | **Status:** UNRESOLVED

- Partner Gateway returns 502 (origin server unreachable behind Cloudflare)
- 13 of 16 microservices unreachable (HTTP 000 — DNS failure or containers not deployed)
- Only 5 services operational: User Management, Admin Auth, Admin Gateway, UI Portal, Admin Portal
- **Workaround:** Sandbox API testing is possible via production gateway (api-partner.onecluster.co)

1.2 Active Directory Not Integrated

Impact: HIGH | **Status:** BY DESIGN (for now)

- Admin authentication uses DemoAdAuthClient with hardcoded ad-users.json seed file
- Production requires UseRealAdAuth=true + bank's AD service URL
- **Risk:** Admin authentication is not production-ready until bank provides AD endpoint (RISK-G1)

1.3 ICAP Malware Scanning Disabled

Impact: HIGH | **Status:** BY DESIGN

- ICAP__Enabled=false in all environments
- KYB document uploads skip antivirus scanning
- FileUploadService performs binary signature inspection (PDF, PNG, JPEG) as partial mitigation
- **Risk:** Infected files could pass through upload pipeline (RISK-G3)

1.4 Email/SMS Notifications Not Functional

Impact: HIGH | **Status:** BY DESIGN

- LoggingNotificationService logs emails to console instead of sending
- No SendGrid API key or SMTP relay configured
- Partners will not receive: verification emails, KYB approval notifications, password reset links
- **Workaround:** /dev/outbox-preview endpoint shows queued notifications in dev
- **Risk:** Pilot onboarding blocked until email gateway provided (RISK-G4)

1.5 Azure Blob WORM Storage Not Provisioned

Impact: HIGH | **Status:** BY DESIGN

- LocalFileSystemDocumentStorage stores KYB documents in /tmp/kyb-docs/
- Not durable, not WORM-compliant, not suitable for production
- AzureBlobDocumentStorage.cs is implemented and ready to activate
- **Risk:** KYB document compliance failure (RISK-G2)

2. Functional Limitations

2.1 Payment Testing Blocked by mTLS

- All /api/v1/payments/* routes require mTLS client certificate
- mTLS is NOT bypassed in sandbox mode (design gap)
- Partners cannot test payment flows without a client certificate
- **Jira:** PEG-380

2.2 Sandbox Response Latency (27-30s)

- Static sandbox mock responses take 27-30 seconds instead of <100ms
- Suspected cause: middleware pipeline executes rate limiting checks against slow/unreachable Redis before sandbox mock intercepts
- Affects developer experience during sandbox integration testing
- **Jira:** PEG-381

2.3 Login Endpoint Returns HTTP 200 for Failures

- POST /api/Auth/login returns 200 with isSuccess:false for invalid credentials
- Standard REST convention is 401 Unauthorized
- API consumers must check isSuccess field instead of HTTP status code
- **Jira:** PEG-379

2.4 API Spec vs Implementation Mismatches

Field	Spec Says	Code Returns	Jira
Collections account number	accountNumber	virtualAccountNumber	PEG-383
Collections prefix	SB-	SB	PEG-383
KYC BVN match result	matchResult	verificationStatus	PEG-384
Collections transactions	data directly	data.transactions (double nested)	PEG-389

2.5 RBAC Endpoint Missing

- GET /api/Profile/GetAllRoles returns 404 on all access paths
- Admin Portal Roles & Permissions page cannot load roles
- RBAC management non-functional
- **Jira:** PEG-382

3. Security Limitations

3.1 Missing Security Headers (Admin Portal)

- X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security, Content-Security-Policy, X-XSS-Protection, Referrer-Policy — all absent
- **Jira:** PEG-377

3.2 API Catalog Publicly Accessible

- GET /api/catalog/products returns full product catalog without authentication
- Exposes subscriber counts, pricing models, endpoint counts
- **Jira:** PEG-378

3.3 Inconsistent Error Response Formats

- Admin Auth: simple {"message":"..."}
- User Management: RFC 7807 {type, title, status, detail, errors}
- Platform standard is RFC 7807 — Admin Auth is non-compliant
- **Jira:** PEG-387

4. Infrastructure Limitations

4.1 No Centralized Logging in Dev

- Serilog Elasticsearch sink requires ElasticsearchUrl config — not set in dev
- Logs only available via container stdout

- No Kibana/Grafana dashboard for log aggregation

4.2 No Health Check Monitoring

- /api/v1/status aggregates health but no automated alerting
- PagerDuty not configured for dev environment
- No auto-restart on container failure

4.3 Redis Configuration Uncertain

- Redis connection strings present in config but Redis health not verifiable from outside
- Rate limiting, circuit breaker, session concurrency all depend on Redis
- If Redis is down, gateway fails open (by design) — no rate limiting protection

5. Deferred Features (Intentionally Not in V1)

- Cards, Lending, FX products
- Bulk payments API
- White-label / multi-tenant architecture
- Custom role builder in admin console
- Advanced fraud/dispute analytics
- Full billing automation and self-service upgrades
- CMS-based documentation editor